

DAK MONITORING SYSTEM

Vulnerability Assessment Report

A. Application Details

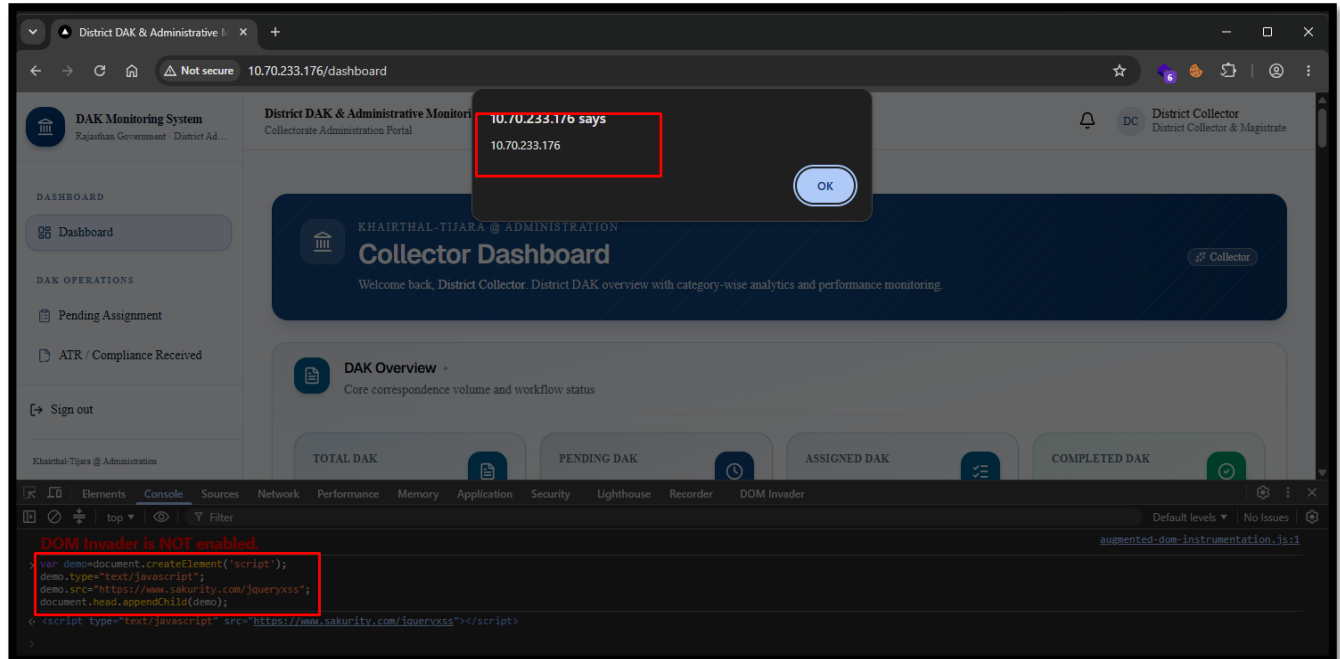
1.	Request ID	DOITC/2026-27/2520
2.	Submission Date	September 14, 2026
3.	Testing URL	http://10.70.233.176

B. Observations:

S.No.	Vulnerabilities	Status
1.	Content Security Policy Bypass	Open
2.	Click Jacking	Open
3.	Sensitive Data Exposure	Open
4.	Vulnerable and Outdated Components	Open

Detailed Vulnerabilities and Recommendation:

- 1. Content Security Policy Bypass:** CSP bypass vulnerabilities arise from misconfigured directives, reliance on unsafe sources, or third-party scripts that don't adhere to policies, allowing attackers to inject malicious code. To mitigate these risks, ensure strict CSP configurations, consistently apply them across all pages, and validate all user inputs.



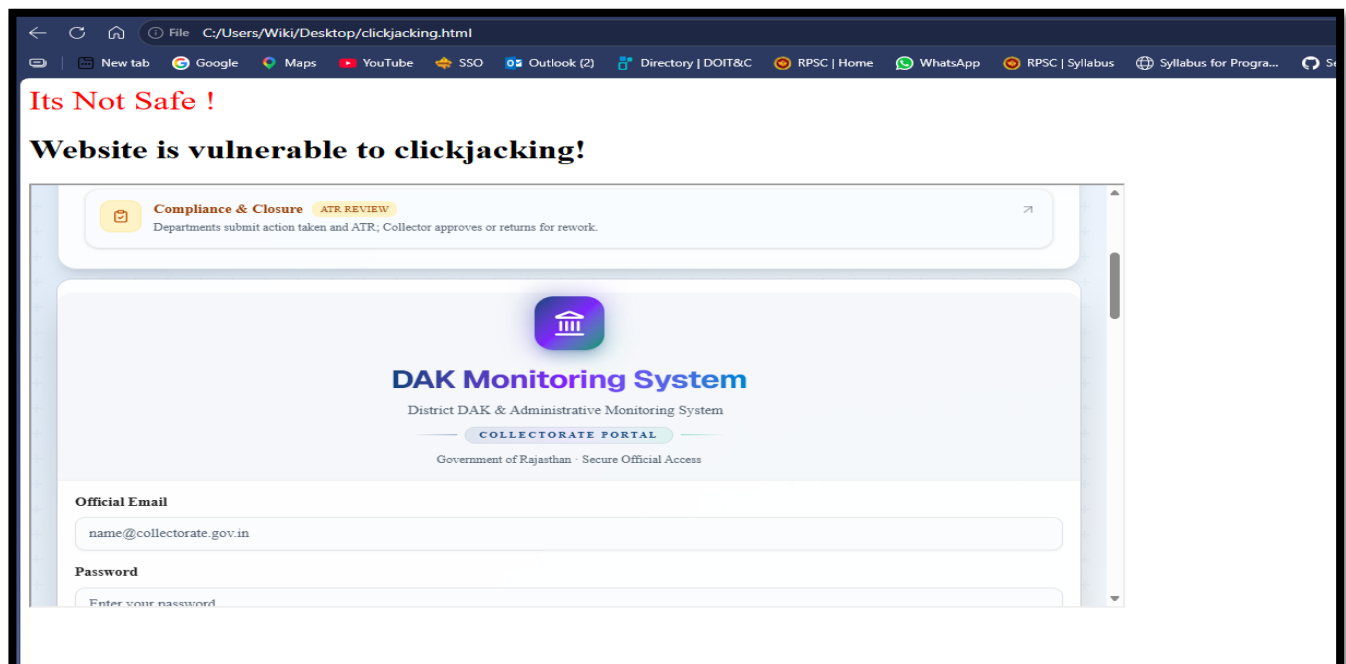
Recommendation: Implement a strict Content Security Policy with no unsafe sources, consistently apply it across all pages, validate and sanitize user inputs, and enable CSP violation reporting for monitoring and response.

2. Click Jacking: The web application is vulnerable to clickjacking or cross-frame scripting. This occurs when a malicious site tricks a user into clicking on something different from what the user perceives, thereby potentially revealing confidential information or taking control of their computer while clicking on seemingly harmless web pages.

Create a specially crafted page that embeds an iframe designed to deceive the end user into performing an action chosen by the attacker. When the page is executed, the target application is loaded within the maliciously crafted frame, as illustrated below.

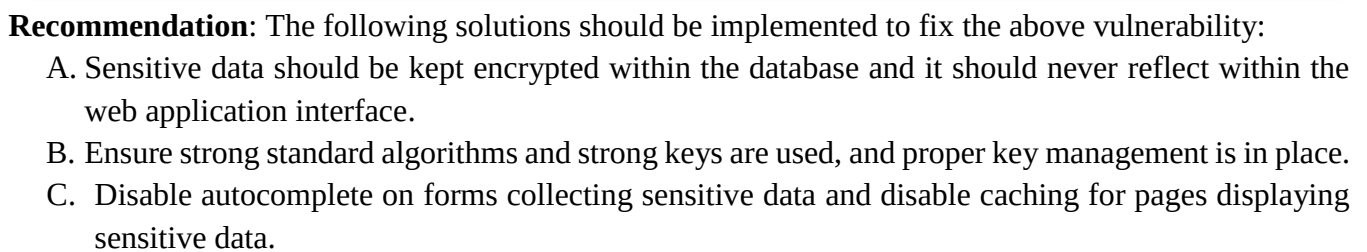
```
<html>
<head>
<title>Clickjack test page</title>
</head>
<body>
<font size="6" color="red">Its Not Safe !</font>

<h1>Website is vulnerable to clickjacking!</h1>
<iframe src="http://10.70.233.176/dashboard" width="1000" height="500"></iframe>
</body>
</html>
```



Recommendation: Preventing Click Jacking requires the implementation of following recommendation:

- A. Implement X-Frame-Options Header: Use the X-Frame-Options HTTP response header to indicate whether a browser should be allowed to render a page in a frame or iframe.
- B. Use Content Security Policy (CSP): Utilise the CSP frame-ancestors directive to control which domains can embed the content.
- C. Regular Security Reviews: Conduct regular security reviews and penetration testing to identify and mitigate clickjacking vulnerabilities.



The screenshot shows the Wappalyzer website with a purple header and a white main content area. The header includes the Wappalyzer logo and navigation links. The main content area is divided into two columns. The left column lists various web technologies, and the right column provides more details about each technology. A red box highlights the following categories and their associated technologies:

- JavaScript frameworks:** React, Next.js (16.2.9)
- Web servers:** Next.js (16.2.9)
- Static site generators:** Next.js (16.2.9)
- Font scripts:** Lucide
- UI frameworks:** Tailwind CSS
- Web frameworks:** Next.js (16.2.9)

DISCLAIMER: Confidential Report, not to be circulated or reproduced without proper Authorization from security audit team.